Plano de Respostas aos Riscos

Projeto: Score Smash

Integrantes:

1- Flávia da Costa Rodrigues Faria – 20021548
2- Guilherme Muniz Gomes – 24026572
3- Lucas Moreira Godoy - 24026298
4- Maria Eduarda Cabral Foloni – 24026502

1. Introdução

O Score Smash é um projeto acadêmico que integra IoT, robótica, programação embarcada e processamento de dados em um jogo físico de precisão: o participante lança uma bolinha em uma arena e o sistema identifica a posição do impacto para calcular a pontuação. A solução encontra-se implementada e é composta por um Arduino Uno, programado em C++/Arduino, que controla 16 lasers e 16 sensores LDR responsáveis por detectar a interrupção dos feixes pela bolinha, lidos por meio de um multiplexador 74HC4067, por uma matriz de LEDs 8x8, controlada por circuitos integrados 74HC595, que indica os alvos e pelos componentes de software que transmitem, armazenam e apresentam os resultados (API, banco de dados e dashboard).

Este Plano de Respostas aos Riscos tem como objetivo definir as respostas aos riscos que podem afetar a confiabilidade da pontuação, a segurança da informação e a disponibilidade do sistema, estabelecendo para cada risco a estratégia de resposta, as ações específicas, os responsáveis, os prazos e o status. Como o sistema já está implementado, as ações concentram-se na verificação, no reforço e na comprovação dos controles na versão atual do Score Smash.

Como ferramenta de apoio à análise, foi utilizado o relatório de auditoria de segurança gerado pelo Aikido Security em 09/11/2026. Na data do relatório, o quadro de problemas em aberto apresentou zero ocorrências em todas as categorias exibidas, e nenhum problema estava fora dos prazos de SLA configurados. O histórico de varreduras registra verificações diárias de dependências de código aberto, de infraestrutura como código, de análise estática de segurança (SAST) em dois repositórios, de detecção de segredos no histórico desses dois repositórios e de um domínio monitorado. Alguns controles das normas mapeadas pelo relatório (como ISO 27001, SOC 2 e CIS) aparecem como “Monitoring, not fully compliant”, o que indica que a ferramenta não reuniu evidências suficientes para considerá-los plenamente atendidos, e não que exista uma vulnerabilidade confirmada. A pontuação referente a ambiente em nuvem consta como N/A.

Dessa forma, os riscos registrados na tabela são preventivos: nenhum deles corresponde a uma vulnerabilidade identificada pelo Aikido. Os resultados do relatório foram utilizados para apontar controles que já contam com monitoramento ativo e pontos que ainda necessitam de comprovação. Ressalta-se, ainda, que o Aikido analisa os repositórios e o domínio, mas não avalia o funcionamento físico do protótipo por isso, riscos como a calibração dos sensores, o cálculo das coordenadas e a segurança dos lasers foram incluídos a partir da análise da arquitetura do projeto.

2. Tabela de Respostas aos Riscos

Esta tabela serve como o núcleo do plano, detalhando a resposta para cada risco priorizado.

ID do Risco	Descrição do Risco	Nível do Risco (Prioridade)	Estratégia de Resposta	Ações Específicas Planejadas	Responsável pela Ação	Prazo para Implementação	Status
SS-01	Exposição de credenciais (string de conexão do banco de dados, chaves ou tokens da API e do dashboard) no código-fonte ou no histórico dos repositórios. Risco preventivo: a varredura de segredos do Aikido de 09/11/2026 não registrou ocorrências.	Alto	Mitigar	1. Manter credenciais apenas em variáveis de ambiente ou em arquivo .env listado no .gitignore, nunca no código da API, do dashboard ou do firmware. 2. Manter a detecção diária de segredos do Aikido nos dois repositórios e analisar todo alerta recebido. 3. Revisar commits e pull requests antes do merge quanto à presença de dados sensíveis. 4. Em caso de exposição, revogar e substituir a credencial imediatamente e remover o dado do histórico.	Equipe de software (API, banco de dados e dashboard)	Contínuo; revisão do .gitignore e das variáveis até 16/11/2026	Em Andamento
SS-02	Leituras incorretas dos 16 sensores LDR, causadas por variação da luz ambiente, desalinhamento dos lasers ou ruído na leitura pelo multiplexador 74HC4067, gerando acertos falsos ou lançamentos não detectados.	Alto	Mitigar	1. Executar rotina de calibração na inicialização, definindo um limiar por sensor a partir das leituras com feixe ativo e interrompido. 2. Confirmar a interrupção somente após leituras consecutivas (filtro) e respeitar o tempo de estabilização a cada troca de canal do 74HC4067. 3. Verificar fixação e alinhamento dos lasers antes de cada sessão de uso. 4. Realizar bateria de lançamentos em todas as regiões da arena e registrar a taxa de detecção correta.	Equipe de hardware e programação embarcada	23/11/2026	Planejado
SS-03	Erros no cálculo das coordenadas do impacto e da pontuação, por mapeamento incorreto entre os canais do multiplexador e as posições da arena ou por interrupções simultâneas e ambíguas de feixes.	Alto	Mitigar	1. Documentar e revisar a tabela de correspondência entre canal, posição na arena e alvo da matriz de LEDs. 2. Definir regra de tratamento para múltiplos feixes interrompidos e uma janela de tempo por lançamento. 3. Testar a função de cálculo com entradas simuladas para os 16 canais e suas combinações. 4. Comparar, nos testes, a pontuação registrada com o alvo indicado na matriz de LEDs.	Equipe de programação embarcada	23/11/2026	Planejado

ID do Risco	Descrição do Risco	Nível do Risco (Prioridade)	Estratégia de Resposta	Ações Específicas Planejadas	Responsável pela Ação	Prazo para Implementação	Status
SS-04	Aceitação, pela API, de dados inválidos, duplicados ou manipulados (coordenadas fora da arena, pontuação incompatível com a posição, campos ausentes), comprometendo o banco de dados e o dashboard.	Alto	Mitigar	1. Validar tipo, formato e faixa de cada campo recebido (coordenadas dentro da arena e pontuações possíveis). 2. Conferir na API a pontuação a partir da coordenada recebida, sem confiar apenas no valor enviado. 3. Rejeitar registros duplicados por identificador ou horário do lançamento, retornando erro adequado. 4. Manter consultas parametrizadas ao banco e testar a API com entradas inválidas e inesperadas.	Equipe de software (API e banco de dados)	23/11/2026	Planejado
SS-05	Acesso não autorizado à API (envio ou alteração de resultados), ao banco de dados ou às funções administrativas do dashboard. Risco preventivo: o Aikido classifica controles de acesso privilegiado, autenticação e gestão de identidade como “Monitoring, not fully compliant”, sem problema aberto.	Alto	Mitigar	1. Exigir autenticação (token ou chave) nas rotas da API que gravam ou alteram resultados. 2. Utilizar usuário de banco com privilégio mínimo e impedir acesso público direto ao banco de dados. 3. Restringir funções administrativas do dashboard (por exemplo, zerar ranking ou excluir partidas) a usuários autenticados. 4. Testar requisições sem credencial e com credencial inválida e registrar os resultados.	Equipe de software (API, banco de dados e dashboard)	30/11/2026	Planejado
SS-06	Uso inseguro dos lasers, com exposição dos olhos de participantes e espectadores aos feixes durante o jogo, a montagem ou a manutenção da arena.	Alto	Prevenir (Evitar)	1. Utilizar somente módulos laser de baixa potência, confirmando a classe no datasheet. 2. Manter os feixes confinados à estrutura da arena, sem direção ao público e fora da altura dos olhos. 3. Desligar os lasers durante montagem, ajuste e manutenção. 4. Sinalizar a arena com aviso de presença de laser.	Equipe de hardware	16/11/2026 (antes da próxima demonstração)	Planejado
SS-07	Interceptação, perda ou alteração dos dados no caminho Arduino Uno → canal intermediário de envio (o Uno não possui interface de rede nativa) → API → banco de dados e dashboard.	Médio	Mitigar	1. Utilizar HTTPS/TLS em todas as chamadas à API e no acesso ao dashboard; o Aikido indica uso de conexões seguras no domínio monitorado, o que deve ser confirmado para todos os endpoints. 2. Incluir no protocolo de envio do Arduino delimitadores e verificação de integridade (por exemplo, checksum), descartando mensagens corrompidas. 3. Armazenar temporariamente e reenviar os resultados quando a API estiver indisponível. 4. Testar a desconexão do cabo ou da rede durante uma partida.	Equipe de integração (embarcado e API)	30/11/2026	Planejado

ID do Risco	Descrição do Risco	Nível do Risco (Prioridade)	Estratégia de Resposta	Ações Específicas Planejadas	Responsável pela Ação	Prazo para Implementação	Status
SS-08	Ausência ou insuficiência de registros de eventos e falhas (calibração, sensores sem resposta, erros de comunicação, requisições rejeitadas, falhas de autenticação), dificultando o diagnóstico. O Aikido classifica o controle de logging como “Monitoring, not fully compliant”.	Médio	Mitigar	1. Registrar na API eventos relevantes com data, horário, origem e resultado (aceito ou rejeitado). 2. Enviar pelo Arduino códigos de status e de erro (calibração, sensor sem resposta) e registrá-los no componente de integração. 3. Não registrar senhas, tokens ou outros segredos nos logs. 4. Revisar os registros após cada sessão de testes.	Equipe de software e equipe de programação embarcada	30/11/2026	Planejado
SS-09	Perda dos resultados armazenados por falha, exclusão acidental ou corrupção do banco de dados. O Aikido classifica o controle de backups como “Monitoring, not fully compliant”.	Médio	Mitigar	1. Realizar exportação periódica (backup) do banco de dados e guardá-la fora do servidor da aplicação. 2. Testar a restauração de um backup em ambiente separado. 3. Restringir operações de exclusão em massa a usuários administrativos.	Equipe de software (banco de dados)	30/11/2026	Planejado
SS-10	Falha ou mau contato em componentes físicos (lasers, LDR, 74HC4067, 74HC595, matriz de LEDs, fiação e alimentação) durante testes ou apresentações.	Médio	Aceitar (Aceitação Ativa)	1. Manter reserva de componentes sobressalentes (lasers, LDR e circuitos integrados). 2. Aplicar checklist de verificação da montagem antes de cada uso. 3. Reservar tempo de contingência no cronograma para reparos. 4. Documentar o esquema de ligações para permitir remontagem rápida.	Equipe de hardware	16/11/2026	Planejado
SS-11	Introdução de vulnerabilidades por bibliotecas de terceiros desatualizadas na API, no dashboard ou no firmware. O Aikido não apontou problemas em dependências nem pendências fora do SLA.	Baixo	Mitigar	1. Manter o monitoramento diário de dependências do Aikido e tratar alertas nos prazos de SLA configurados (crítico: 5 dias; alto: 20 dias). 2. Fixar as versões das dependências utilizadas. 3. Verificar manualmente a origem e a versão das bibliotecas Arduino utilizadas.	Equipe de software e equipe de programação embarcada	Contínuo; revisão a cada entrega	Em Andamento

3. Detalhamento das Estratégias de Resposta

Estratégias para Ameaças (Riscos Negativos)

- **Prevenir (Evitar):** Mudar o plano do projeto para eliminar a ameaça por completo. Significa não realizar a atividade que contém o risco.
    - Exemplo: No Score Smash, manter os feixes de laser confinados à estrutura da arena e utilizar apenas módulos de baixa potência elimina a exposição dos participantes, em vez de apenas reduzi-la (SS-06).
- **Transferir:** Repassar o impacto negativo do risco (e a responsabilidade pela resposta) para um terceiro. Não elimina o risco, apenas o transfere.
    - Exemplo: Hospedar a API ou o banco de dados em um serviço gerenciado transfere ao provedor parte da responsabilidade pela infraestrutura e pela disponibilidade. Nenhum risco da tabela adota esta estratégia como resposta principal, pois os riscos identificados dependem de ações da própria equipe.
- **Mitigar:** Reduzir a probabilidade de ocorrência do risco e/ou seu impacto no projeto a um nível aceitável.
    - Exemplo: Calibrar os sensores LDR, testar o cálculo das coordenadas, validar os dados na API, restringir acessos e registrar eventos (SS-01 a SS-05, SS-07 a SS-09 e SS-11). É a estratégia predominante do plano, pois esses riscos não podem ser eliminados sem descaracterizar o projeto.
- **Aceitar:** Nenhuma ação proativa é tomada para alterar o plano do projeto.
    - **Aceitação Ativa:** Criar uma reserva de contingência (tempo, dinheiro) para lidar com o risco caso ele ocorra. No Score Smash, aplica-se à falha de componentes físicos, com reserva de peças sobressalentes e de tempo no cronograma (SS-10).
    - **Aceitação Passiva:** Não fazer nada e lidar com as consequências se o risco se materializar (geralmente para riscos de baixa prioridade). Pode ser aplicada, por exemplo, a pequenas variações no tempo de atualização do dashboard que não afetem a pontuação registrada.

3.2. Estratégias para Oportunidades (Riscos Positivos)

- **Explorar:** Tomar ações para garantir que a oportunidade se concretize.
    - Exemplo: Utilizar os resultados já armazenados no banco de dados para apresentar no dashboard estatísticas de desempenho por jogador, agregando valor ao Score Smash.

- **Melhorar (ou Realçar):** Aumentar a probabilidade de ocorrência da oportunidade e/ou seu impacto positivo.
    - Exemplo: Aprofundar o uso do Aikido Security pela equipe, para acompanhar os alertas e reunir evidências dos controles classificados como “Monitoring, not fully compliant”.
- **Compartilhar:** Alocar a responsabilidade da oportunidade a um terceiro que esteja mais apto a aproveitá-la em benefício do projeto.
    - Exemplo: Firmar parceria com um laboratório da instituição ou com outra equipe acadêmica para validar a precisão da detecção ou expor o Score Smash em eventos.
- **Aceitar:** Não buscar ativamente a oportunidade, mas aproveitá-la se ela acontecer.
    - Exemplo*:* Caso surja um convite para apresentar o Score Smash em uma feira acadêmica, aproveitar a oportunidade sem alterar o cronograma planejado.

4. Monitoramento e Revisão

Este plano será revisado semanalmente pela equipe até a entrega final do projeto e, de forma extraordinária, sempre que houver alteração relevante no firmware do Arduino, na montagem física da arena, na API, no banco de dados ou no dashboard. O líder do projeto consolidará o status de cada ação na tabela, utilizando os valores Planejado, Em Andamento, Concluído ou Cancelado.

Uma ação somente será marcada como Concluído quando houver evidência registrada de sua execução, como resultados de testes, commits, capturas de configuração ou relatórios. Para os riscos do protótipo físico, serão acompanhados a taxa de detecção correta nos testes de lançamento e a coerência entre a pontuação registrada e o alvo indicado na matriz de LEDs. Para os componentes de software, serão acompanhados os resultados dos testes de entradas inválidas, de acesso sem autenticação e de restauração de backup.

O monitoramento contínuo do Aikido Security será mantido, com análise dos alertas recebidos em tempo real e tratamento dentro dos prazos de SLA configurados. Um novo relatório deverá ser gerado a cada entrega e comparado ao relatório de 09/11/2026. Os controles classificados como “Monitoring, not fully compliant” serão analisados para verificar se se aplicam à arquitetura do Score Smash e quais evidências podem comprová-los, sem que sejam tratados como vulnerabilidades confirmadas.

Novos riscos poderão ser adicionados e os riscos existentes reavaliados quanto à prioridade e à estratégia, com o registro de uma nova versão do documento a cada atualização. A ausência de vulnerabilidades abertas no relatório do Aikido não elimina a necessidade de testes e revisões periódicas, sobretudo para os riscos físicos e de lógica de pontuação, que não são cobertos pela ferramenta.